Playbook SOC — Échecs de connexion Windows

Version : 26 septembre 2026
Périmètre : windows-client1, journaux Security reçus dans winlogbeat-*
État : playbook prêt à appliquer. La règle 4625 déjà active signale chaque événement ; la règle à seuil proposée ci-dessous n'est pas encore créée ni validée dans Kibana.

1. Risque surveillé

Plusieurs mots de passe incorrects pour un même compte, en peu de temps, peuvent signaler une tentative d'accès non autorisée. Un échec isolé est souvent une erreur ordinaire. Une connexion réussie après une série d'échecs appelle une vérification prioritaire, sans prouver à elle seule une compromission.

2. Détection automatique à configurer dans Elastic Security

Dans **Security → Règles → Créer une règle**, choisir **Seuil (Threshold)**.

Paramètre	Valeur proposée
Nom	SOC Windows — 5 échecs sur un même compte et poste
Index	winlogPlaybook SOC — Échecs de connexion Windows **Version :** 26 septembre 2026 **Périmètre :** windows-client1, journaux Security reçus dans winlogbeat-* **État :** playbook prêt à appliquer. La règle 4625 déjà active signale chaque événement ; la règle à seuil proposée ci-dessous n'est pas encore créée ni validée dans Kibana. ## 1. Risque surveillé Plusieurs mots de passe incorrects pour un même compte, en peu de temps, peuvent signaler une tentative d'accès non autorisée. Un échec isolé est souvent une erreur ordinaire. Une connexion réussie après une série d'échecs appelle une vérification prioritaire, sans prouver à elle seule une compromission. ## 2. Détection automatique à configurer dans Elastic Security Dans **Security → Règles → Créer une règle**, choisir **Seuil (Threshold)**.

Paramètre	Valeur proposée
Nom	SOC Windows — 5 échecs sur un même compte et poste
Index	winlogbeat-*
Langage	KQL
Requête	event.code.keyword: "4625" and winlog.channel.keyword: "Security" and

	winlog.provider_name.keyword: "Microsoft-Windows-Security-Auditing"
Regrouper par	host.name et winlog.event_data.TargetUserName.keyword
Seuil	Au moins **5** événements par groupe
Exécution	Toutes les **5 minutes** ; **6 minutes** de temps de récupération supplémentaire, soit ur recherche d'environ **11 minutes** à chaque passage
Gravité initiale	Moyenne ; score de risque indicatif 47
Réduction des doublons	Si disponible dans cette licence, limiter à une alerte par groupe pendant 15 minutes sinon surveiller les doublons et ajuster après vérification



Cette règle produit une alerte de synthèse pour le **compte et le poste** qui franchissent le seuil. L'analyste doit ouvrir les événements d'origine pour connaître les adresses IP, les types de connexion et les statuts Windows ; les champs non utilisés pour le regroupement peuvent manquer dans l'alerte de seuil.

Avant activation : contrôler dans Kibana que les deux champs du regroupement sont disponibles et agrégeables. Prévisualiser la règle sur les événements du 22 septembre 2026 : les cinq échecs de soc-test, entre 14 h 41 et 14 h 48 (heure de Paris), doivent être retrouvés dans une fenêtre d'environ onze minutes. Une exécution planifiée courante ne remontera pas automatiquement ces événements historiques. Après validation, envisager de désactiver la règle actuelle qui alerte à

chaque 4625 afin d'éviter les doublons ; conserver sa définition dans le rapport.

3. Deuxième détection à configurer : création de compte local

Dans **Security → Règles → Créer une règle**, choisir **Requête personnalisée (Custom query)**. Source : winlogbeat-* ; KQL : event.code.keyword: "4720" and winlog.channel.keyword: "Security" and winlog.provider_name.keyword: "Microsoft-Windows-Security-Auditing". Nom : SOC Windows — compte local créé. Exécution toutes les **5 minutes** avec **1 minute** supplémentaire pour les retards ; gravité initiale **moyenne**. Un événement 4720 produit une alerte à examiner, car la création d'un compte peut être légitime ou non autorisée. Ne pas exclure définitivement soc-test : documenter la fenêtre du test dans l'analyse. Vérifier les champs SubjectUserName (compte créateur), TargetUserName (compte créé), host.name et les connexions 4624/4625 de ce compte.

Cette seconde règle n'est **pas encore installée ni testée** ; l'événement historique 4720 de soc-test permet de la prévisualiser sans recréer de compte.

4. Triage : que vérifier quand l'alerte arrive ?

1. **Identifier :** poste (host.name), compte visé (TargetUserName), nombre d'échecs et période.
2. **Chercher la source :** IpAddress, LogonType, ProcessName, Status et SubStatus dans les événements 4625 d'origine. ::1 désigne une origine locale ; toute autre adresse doit être replacée dans le réseau et le contexte de l'utilisateur.
3. **Chercher ce qui précède et suit :** événements **4720** (création du compte) et **4624** (connexion réussie) pour le même compte et le même poste, en particulier après les échecs. Comparer les heures, l'adresse et le type de connexion ; vérifier la période réellement couverte par les journaux.
4. **Qualifier :** test autorisé ou erreur utilisateur connue → activité attendue ; origine inconnue, compte sensible, plusieurs postes ou succès inexpliqué → investigation prioritaire et ouverture d'un dossier d'incident.
5. **Répondre :** conserver les événements et la chronologie ; contacter l'administrateur du poste ou du compte ; faire réinitialiser les accès ou isoler la machine seulement après confirmation et selon la procédure de l'organisation. Documenter la décision et les éléments manquants.

5. Automatisation et limites

- **Automatique dès activation :** recherche planifiée, comptage des échecs par compte et poste, et alerte lorsqu'un seuil est atteint ; alerte distincte à chaque création de compte local.

- **Option conditionnelle :** notifier un analyste via une *action* et un connecteur Kibana si la licence, les droits et le connecteur sont disponibles. Ce n'est pas encore configuré ni testé.
- **À garder sous contrôle humain :** qualification d'incident, ouverture d'un dossier, blocage de compte ou isolement de poste. Une alerte ne prouve pas une intrusion.
- **À ne pas généraliser sans correction des données :** les échecs SSH Linux. Une ligne repeated 2 times: [Failed password… a été classée comme message sans event.outcome=failure ; une règle fondée seulement sur ce champ manquerait une partie des échecs.
- **Fichiers suspects :** aucun détecteur spécifique n'est annoncé ici comme actif. Définir d'abord quels événements relatifs aux fichiers ou aux processus sont réellement collectés et quel comportement est suspect ; la simple modification d'un fichier de test ne suffit pas.

6. Exemple de décision documentée : soc-test

Le 22 septembre, Safia a créé le compte soc-test (événement 4720), puis cinq connexions locales ont échoué en environ six minutes (4625). Les journaux examinés ne montrent pas de connexion réussie de ce compte depuis sa création. L'origine ::1, le type de connexion interactif et le contexte d'essai contrôlé justifient le classement **test autorisé détecté, pas d'intrusion démontrée**. Ce cas valide le raisonnement de triage ; il ne valide pas encore l'exécution de la nouvelle règle à seuil, qui reste à créer et à prévisualiser.



Playbook – création d’un compte Windows.

La création d’un compte est un événement à examiner, car elle peut correspondre aussi bien à une opération autorisée qu’à une action suspecte. Le journal Security du poste DESKTOP-EHQ529H contient un événement **4720** daté du 22 septembre 2026 à 13 h 38 (heure française) : le compte soc-test a été créé et le compte Safia figure comme auteur dans le journal. Pour assurer la surveillance de ce type d’événement, j’ai activé dans Kibana la règle « SOC | Windows | Création d’un compte (4720) ». Le playbook prévoit alors de vérifier l’identité du compte créé, l’auteur indiqué, l’autorisation de la création et les droits accordés avant de qualifier l’alerte. Dans ce cas, les journaux prouvent la création du compte, mais ne permettent pas, à eux seuls, d’établir qu’il s’agit d’un incident.

	beat-*
Langage	KQL
Requête	event.code.keyword: "4625" and winlog.channel.keyword: "Security" and winlog.provider_name.keyword: "Microsoft-Windows-Security-Auditing"
Regrouper par	host.name et winlog.event_data.TargetUserName.keyword
Seuil	Au moins **5** événements par groupe
Exécution	Toutes les **5 minutes** ; **6 minutes** de temps de récupération supplémentaire, soit une recherche d'environ **11 minutes** à chaque passage
Gravité initiale	Moyenne ; score de risque indicatif 47
Réduction des doublons	Si disponible dans cette licence, limiter à une alerte par groupe pendant 15 minutes ; sinon surveiller les doublons et ajuster après vérification



Cette règle produit une alerte de synthèse pour le **compte et le poste** qui franchissent le seuil. L'analyste doit ouvrir les événements d'origine pour connaître les adresses IP, les types de connexion et les statuts Windows ; les champs non utilisés pour le regroupement peuvent manquer dans l'alerte de seuil.

Avant activation : contrôler dans Kibana que les deux champs du regroupement sont disponibles et agrégeables. Prévisualiser la règle sur les événements du 22 septembre 2026 : les cinq échecs de soc-test, entre 14 h 41 et 14 h 48 (heure de Paris), doivent être retrouvés dans une fenêtre d'environ onze minutes. Une exécution planifiée courante ne remontera pas automatiquement ces événements historiques. Après validation, envisager de désactiver la règle actuelle qui alerte à chaque 4625 afin d'éviter les doublons ; conserver sa définition dans le rapport.

3. Deuxième détection à configurer : création de compte local

Dans **Security → Règles → Créer une règle**, choisir **Requête personnalisée (Custom query)**. Source : winlogbeat-* ; KQL : event.code.keyword: "4720" and winlog.channel.keyword: "Security" and winlog.provider_name.keyword: "Microsoft-Windows-Security-Auditing". Nom : SOC Windows — compte local créé. Exécution toutes les **5 minutes** avec **1 minute** supplémentaire pour les retards ; gravité initiale **moyenne**. Un événement 4720 produit une alerte à examiner, car la création d'un compte peut être légitime ou non autorisée. Ne pas exclure définitivement soc-test : documenter la fenêtre du test dans l'analyse. Vérifier les champs SubjectUserName (compte créateur), TargetUserName (compte créé), host.name et les connexions 4624/4625 de ce compte.

Cette seconde règle n'est **pas encore installée ni testée** ; l'événement historique 4720 de soc-test permet de la prévisualiser sans recréer de compte.

4. Triage : que vérifier quand l'alerte arrive ?

6. **Identifier :** poPlaybook SOC — Échecs de connexion Windows
7.
8. **Version :** 26 septembre 2026
   Périmètre : windows-client1, journaux Security reçus dans winlogbeat-*
   État : playbook prêt à appliquer. La règle 4625 déjà active signale chaque événement ; la règle à seuil proposée ci-dessous n'est pas encore créée ni validée dans Kibana.

9.1. Risque surveillé

10. Plusieurs mots de passe incorrects pour un même compte, en peu de temps, peuvent signaler une tentative d'accès non autorisée. Un échec isolé est souvent une erreur ordinaire. Une connexion réussie après une série d'échecs appelle une vérification prioritaire, sans prouver à elle seule une compromission.

11.2. Détection automatique à configurer dans Elastic Security

12. Dans **Security → Règles → Créer une règle**, choisir **Seuil (Threshold)**.

13. Paramètre	14. Valeur proposée
15. Nom	16. SOC Windows — 5 échecs sur un même compte et poste
17. Index	18. winlogbeat-*
19. Langage	20. KQL
21. Requête	22. event.code.keyword: "4625" and winlog.channel.keyword: "Security" and winlog.provider_name.keyword: "Microsoft-Windows-Security-Auditing"
23. Regrouper par	24. host.name et winlog.event_data.TargetUserName.keyword
25. Seuil	26. Au moins **5** événements par groupe
27. Exécution	28. Toutes les **5 minutes** ; **6 minutes** de temps de récupération supplémentaire, soit une recherche d'environ **11 minutes** à chaque passage
29. Gravité initiale	30. Moyenne ; score de risque indicatif 47
31. Réduction des doublons	32. Si disponible dans cette licence, limiter à une alerte par groupe pendant 15 minutes ; sinon surveiller les doublons et ajuster après vérification

33.

34.

35.

36.

37.



38.

39. Cette règle produit une alerte de synthèse pour le **compte et le poste** qui franchissent le seuil. L'analyste doit ouvrir les événements d'origine pour connaître les adresses IP, les types de connexion et les statuts Windows ; les champs non utilisés pour le regroupement peuvent manquer dans l'alerte de seuil.

40. **Avant activation :** contrôler dans Kibana que les deux champs du regroupement sont disponibles et agrégeables. Prévisualiser la règle sur les événements du 22 septembre 2026 : les cinq échecs de soc-test, entre 14 h 41 et 14 h 48 (heure de Paris), doivent être retrouvés dans une fenêtre d'environ onze minutes. Une exécution planifiée courante ne remontera pas automatiquement ces événements historiques. Après validation, envisager de désactiver la règle actuelle qui alerte à chaque 4625 afin d'éviter les doublons ; conserver sa définition dans le rapport.

41.3. Deuxième détection à configurer : création de compte local

42. Dans **Security → Règles → Créer une règle**, choisir **Requête personnalisée (Custom query)**. Source : winlogbeat-* ; KQL : event.code.keyword: "4720" and winlog.channel.keyword: "Security" and winlog.provider_name.keyword: "Microsoft-Windows-Security-Auditing". Nom : SOC Windows — compte local créé. Exécution toutes les **5 minutes** avec **1 minute** supplémentaire pour les retards ; gravité initiale **moyenne**. Un événement 4720 produit une alerte à examiner, car la création d'un compte peut être légitime

ou non autorisée. Ne pas exclure définitivement soc-test : documenter la fenêtre du test dans l'analyse. Vérifier les champs SubjectUserName (compte créateur), TargetUserName (compte créé), host.name et les connexions 4624/4625 de ce compte.

43. Cette seconde règle n'est **pas encore installée ni testée** ; l'événement historique 4720 de soc-test permet de la prévisualiser sans recréer de compte.

44.4. Triage : que vérifier quand l'alerte arrive ?

45. **Identifier :** poste (host.name), compte visé (TargetUserName), nombre d'échecs et période.

46. **Chercher la source :** IpAddress, LogonType, ProcessName, Status et SubStatus dans les événements 4625 d'origine. ::1 désigne une origine locale ; toute autre adresse doit être replacée dans le réseau et le contexte de l'utilisateur.

47. **Chercher ce qui précède et suit :** événements **4720** (création du compte) et **4624** (connexion réussie) pour le même compte et le même poste, en particulier après les échecs. Comparer les heures, l'adresse et le type de connexion ; vérifier la période réellement couverte par les journaux.

48. **Qualifier :** test autorisé ou erreur utilisateur connue → activité attendue ; origine inconnue, compte sensible, plusieurs postes ou succès inexpliqué → investigation prioritaire et ouverture d'un dossier d'incident.

49. **Répondre :** conserver les événements et la chronologie ; contacter l'administrateur du poste ou du compte ; faire réinitialiser les accès ou isoler la machine seulement après confirmation et selon la procédure de l'organisation. Documenter la décision et les éléments manquants.

50.5. Automatisation et limites

51. **Automatique dès activation :** recherche planifiée, comptage des échecs par compte et poste, et alerte lorsqu'un seuil est atteint ; alerte distincte à chaque création de compte local.

52. **Option conditionnelle :** notifier un analyste via une *action* et un connecteur Kibana si la licence, les droits et le connecteur sont disponibles. Ce n'est pas encore configuré ni testé.

53. **À garder sous contrôle humain :** qualification d'incident, ouverture d'un dossier, blocage de compte ou isolement de poste. Une alerte ne prouve pas une intrusion.

54. **À ne pas généraliser sans correction des données :** les échecs SSH Linux. Une ligne repeated 2 times: [Failed password… a été classée comme message sans event.outcome=failure ; une règle fondée seulement sur ce champ manquerait une partie des échecs.

55. **Fichiers suspects :** aucun détecteur spécifique n'est annoncé ici comme actif. Définir d'abord quels événements relatifs aux fichiers ou aux processus sont réellement collectés et quel comportement est suspect ; la simple modification d'un fichier de test ne suffit pas.

56.6. Exemple de décision documentée : soc-test

57. Le 22 septembre, Safia a créé le compte soc-test (événement 4720), puis cinq connexions locales ont échoué en environ six minutes (4625). Les journaux examinés ne montrent pas de connexion réussie de ce compte depuis sa création. L'origine ::1, le type de connexion interactif et le contexte d'essai contrôlé justifient le classement **test autorisé détecté, pas d'intrusion démontrée**. Ce cas valide le raisonnement de triage ; il ne valide pas encore l'exécution de la nouvelle règle à seuil, qui reste à créer et à prévisualiser.

58.



59.

60. Playbook – création d'un compte Windows.

61. La création d'un compte est un événement à examiner, car elle peut correspondre aussi bien à une opération autorisée qu'à une action suspecte. Le journal Security du poste DESKTOP-EHQ529H contient un événement **4720** daté du 22 septembre 2026 à 13 h 38 (heure française) : le compte soc-test a été créé et le compte Safia figure comme auteur dans le journal. Pour assurer la surveillance de ce type d'événement, j'ai activé dans Kibana la règle « SOC | Windows | Création d'un compte (4720) ». Le playbook prévoit alors de vérifier l'identité du compte créé, l'auteur indiqué, l'autorisation de la création et les droits accordés avant de qualifier l'alerte. Dans ce cas, les journaux prouvent la création du compte, mais ne permettent pas, à eux seuls, d'établir qu'il s'agit d'un incident.

62. ste (host.name), compte visé (TargetUserName), nombre d'échecs et période.

63. **Chercher la source :** IpAddress, LogonType, ProcessName, Status et SubStatus dans les événements 4625 d'origine. ::1 désigne une origine locale ; toute autre adresse doit être replacée dans le réseau et le contexte de l'utilisateur.

64. **Chercher ce qui précède et suit :** événements **4720** (création du compte) et **4624** (connexion réussie) pour le même compte et le même poste, en particulier après les échecs.

Comparer les heures, l'adresse et le type de connexion ; vérifier la période réellement couverte par les journaux.

65. **Qualifier :** test autorisé ou erreur utilisateur connue → activité attendue ; origine inconnue, compte sensible, plusieurs postes ou succès inexpliqué → investigation prioritaire et ouverture d'un dossier d'incident.

66. **Répondre :** conserver les événements et la chronologie ; contacter l'administrateur du poste ou du compte ; faire réinitialiser les accès ou isoler la machine seulement après confirmation et selon la procédure de l'organisation. Documenter la décision et les éléments manquants.

5. Automatisation et limites

- **Automatique dès activation :** recherche planifiée, comptage des échecs par compte et poste, et alerte lorsqu'un seuil est atteint ; alerte distincte à chaque création de compte local.
- **Option conditionnelle :** notifier un analyste via une *action* et un connecteur Kibana si la licence, les droits et le connecteur sont disponibles. Ce n'est pas encore configuré ni testé.
- **À garder sous contrôle humain :** qualification d'incident, ouverture d'un dossier, blocage de compte ou isolement de poste. Une alerte ne prouve pas une intrusion.
- **À ne pas généraliser sans correction des données :** les échecs SSH Linux. Une ligne repeated 2 times: [Failed password… a été classée comme message sans event.outcome=failure ; une règle fondée seulement sur ce champ manquerait une partie des échecs.
- **Fichiers suspects :** aucun détecteur spécifique n'est annoncé ici comme actif. Définir d'abord quels événements relatifs aux fichiers ou aux processus sont réellement collectés et quel comportement est suspect ; la simple modification d'un fichier de test ne suffit pas.

6. Exemple de décision documentée : soc-test

Le 22 septembre, Safia a créé le compte soc-test (événement 4720), puis cinq connexions locales ont échoué en environ six minutes (4625). Les journaux examinés ne montrent pas de connexion réussie de ce compte depuis sa création. L'origine ::1, le type de connexion interactif et le contexte d'essai contrôlé justifient le classement **test autorisé détecté, pas d'intrusion démontrée**. Ce cas valide le raisonnement de triage ; il ne valide pas encore l'exécution de la nouvelle règle à seuil, qui reste à créer et à prévisualiser.



Playbook – création d'un compte Windows.

La création d'un compte est un événement à examiner, car elle peut correspondre aussi bien à une opération autorisée qu'à une action suspecte. Le journal Security du poste DESKTOP-EHQ529H contient un événement **4720** daté du 22 septembre 2026 à 13 h 38 (heure française) : le compte soc-test a été créé et le compte Safia figure comme auteur dans le journal. Pour assurer la surveillance de ce type d'événement, j'ai activé dans Kibana la règle « SOC | Windows | Création d'un compte (4720) ». Le playbook prévoit alors de vérifier l'identité du compte créé, l'auteur indiqué, l'autorisation de la création et les droits accordés avant de qualifier l'alerte. Dans ce cas, les journaux prouvent la création du compte, mais ne permettent pas, à eux seuls, d'établir qu'il s'agit d'un incident.